Guida passo-passo — Prima review esterna del Genesis Trust Framework

Per: Radixia srl (radixia.ai) · **Committente**: Spazio Genesi ETS (it@spaziogenesi.org)
Riferimenti: processo `PRC-review-esterna-annuale`, decisione `ADR-GTF-010`,
piano operativo `docs/piano-review-esterna-2026.md` (questo file lo rende eseguibile passo per passo, senza dare per scontata familiarità con Git/Node.js)

Questa guida presuppone competenze informatiche generali (terminale, file, browser), ma **non** che chi la segue sia un programmatore. Ogni comando è spiegato prima di essere dato; dove possibile è indicata anche l'alternativa "solo browser".

---

0. Cosa state per fare (in due frasi)

State verificando, con occhi esterni e indipendenti, che ciò che il registro pubblico del Genesis Trust Framework *dichiara* sul servizio di attestazione digitale spaziogenesi.org sia davvero sostenuto da prove verificabili. Non è un audit di certificazione (non c'è uno standard con cui confrontarsi), è un controllo di onestà: "quello che dicono di avere fatto, l'hanno fatto davvero?".

L'esito è un **verbale pubblico** — un documento, anche breve, che chiunque potrà leggere sul sito trust.spaziogenesi.org.

---

1. Cosa vi serve prima di iniziare

Nessuna credenziale, nessun accesso da richiedere: tutto il materiale è pubblico per design. Vi servono solo strumenti sul vostro computer:

Strumento	A cosa serve	Come verificare se c'è già
Un browser	leggere registro, sito, repository su GitHub	(già lo state usando)
Un terminale	eseguire due comandi (passo 3)	Terminale (Mac/Linux) o PowerShell/cmd (Windows)
Git	scaricare una copia del registro	apri il terminale e digita `git --version`
Node.js (versione 20 o superiore)	far girare lo script che ricalcola il punteggio	apri il terminale e digita `node --version`

Se `git --version` risponde con un numero di versione (es. `git version 2.43.0`), Git è già installato. Se dà errore "comando non trovato", scaricatelo da **git-scm.com/downloads** (installazione standard, non serve configurare nulla).

Se `node --version` risponde con `v20.x.x` o superiore, siete a posto. Se manca o è più vecchio, scaricate la versione **LTS** da **nodejs.org** (installazione standard, "Next, Next, Finish").

> Se preferite **non installare nulla**, potete comunque fare i passi 4-5 (lettura del registro) direttamente su GitHub via browser — solo il passo 3 (verifica del punteggio) richiede Git+Node, ed è il passo più importante: è l'unico che dimostra che il punteggio pubblicato non è "a mano", ma calcolato da un programma a partire solo dai dati committati.

---

2. Passo 1 — Scaricare una copia del registro ("clonare il repository")

"Clonare" significa scaricare sul vostro computer una copia completa del repository pubblico (codice, dati, storia delle modifiche).

Aprite il terminale, spostatevi in una cartella qualunque dove va bene creare una sottocartella nuova (es. Documenti), poi:

```
git clone https://github.com/SPAZIO-GENESI/gtf.git
cd gtf
```

Il primo comando crea una cartella `gtf` con dentro tutto il repository. Il secondo (`cd gtf`, "cambia cartella") vi porta dentro. Da qui in poi tutti i comandi dei prossimi passi si eseguono restando in questa cartella.

(In alternativa, per solo guardare senza scaricare nulla: https://github.com/SPAZIO-GENESI/gtf)

---

3. Passo 2 — Il test cardine: il punteggio è davvero riproducibile?

Questo è il passo più importante dell'intera review. L'idea è: il punteggio pubblicato su trust.spaziogenesi.org (l'"Open Trust Score") **non deve essere preso per buono** — va ricalcolato da zero sul vostro computer, partendo solo dai file di dati presenti nel repository, e deve coincidere.

Due comandi, sempre dentro la cartella `gtf`:

```
npm ci
```

Scarica le poche librerie necessarie (elencate in `package.json`, niente di esotico: un validatore di schemi e un parser YAML). Richiede una connessione internet la prima volta, dura circa un minuto.

```
npm run build
```

Questo esegue in sequenza i controlli automatici e rigenera il sito. Output atteso (estratto da un'esecuzione reale del 20/10/2026 — i numeri esatti possono differire di poco a seconda di quando lo eseguite, ma la forma deve essere questa; le righe intermedie sulle cadenze e sul sito sono omesse):

```
> gtf@0.1.0 validate
> node core/generators/validate.mjs

Registro GTF valido: 282 record, 0 errori.

> gtf@0.1.0 score
> node core/generators/score.mjs

Score calcolato: 92/100 (10/10 indicatori disponibili).

> gtf@0.1.0 build-site
> node core/generators/build-site.mjs

site/index.html + site/en/index.html generati.
```

Nota: `npm run build` rigenera anche i file in `site/` e `tenants/attestazione/site/` nella vostra copia locale; è normale e non modifica nulla online.

Cosa verificare:

1. La prima riga deve dire **"0 errori"**. Se dice un numero diverso da zero, è già un rilievo da annotare (il registro non passa la propria stessa validazione).
2. Il numero dopo "Score calcolato" (es. `92/100`) deve **coincidere** con quello mostrato in home su **https://trust.spaziogenesi.org** al momento della vostra verifica. Se il sito mostra un numero diverso, annotatelo come rilievo (potrebbe voler dire che il sito pubblicato non riflette l'ultima versione del registro, oppure che c'è un problema nella pipeline che lo pubblica).
3. Non deve esserci **nessuna chiamata di rete** durante `npm run score` (lo script che calcola il punteggio): è una scelta di design dichiarata (il punteggio deve essere calcolabile anche offline, per essere davvero riproducibile). Se volete verificarlo concretamente, potete rilanciare `npm run score` **staccando la connessione internet**: deve dare lo stesso identico risultato.

Se tutti e tre i punti tornano, questo passo è "superato" — annotatelo così nel verbale.

---

4. Passo 3 — Esaminare un campione di controlli reali

Qui si scende nel dettaglio: scegliete **almeno 5 controlli** (`CTL-*`, il tipo di record che rappresenta una misura di sicurezza/qualità realmente attiva) e per ciascuno verificate tre cose. Non serve leggere codice riga per riga: serve controllare che i **collegamenti dichiarati esistano davvero**.

Come sono fatti i dati (struttura, per orientarvi)

Il registro è la cartella `tenants/attestazione/registry/` con sottocartelle per tipo di record, tutti file di testo in formato YAML (leggibili anche senza editor speciale, va bene il Blocco Note o direttamente GitHub via browser):

```
tenants/attestazione/registry/
  controls/        → CTL-*.yaml   (i controlli: cosa è stato fatto)
  implementations/  → IMP-*.yaml   (dove, nel codice, il controllo è implementato)
  evidence/         → EVD-*.yaml   (le prove concrete: log, screenshot, run pubblici)
  requirements/     → REQ-*.yaml   (i requisiti/norme che il controllo soddisfa)
  risks/            → RSK-*.yaml   (i rischi che il controllo mitiga)
  processes/        → PRC-*.yaml   (i processi ricorrenti, come questa stessa review)
  decisions/        → ADR-*.yaml   (le decisioni architetturali, col perché)
```

Ogni file `CTL-*.yaml` ha (tra gli altri) questi campi — è quello che dovete leggere:

- `status`: deve essere `active` per i controlli che scegliete (`draft` = non ancora operativo, escludeteli dal campione)
- `implemented_by`: punta a un record `IMP-*` che descrive **dove nel codice** vive il controllo
- `evidenced_by`: punta a un record `EVD-*` che descrive **la prova concreta** (un log, un run di CI pubblico, un dato osservabile)

I 5 controlli suggeriti (potete sceglierne altri, questi sono un punto di partenza comodo)

Per ciascuno, un link diretto al file su GitHub (potete aprirli nel browser senza aver clonato nulla) e cosa cercare:

1. `CTL-hmac-canary` — https://github.com/SPAZIO-GENESI/gtf/blob/main/tenants/attestazione/registry/controls/CTL-hmac-canary.yaml Verificabile "dal vivo": è un controllo che il servizio esegue su sé stesso a ogni campionamento. L'`EVD` collegato dovrebbe indicare dove osservarlo (tipicamente `GET https://imgauth.spaziogenesi.org/api/status` nel browser — il campo `worker` deve risultare `ok`).
2. `CTL-dogfooding-anchor` — https://github.com/SPAZIO-GENESI/gtf/blob/main/tenants/attestazione/registry/controls/CTL-dogfooding-anchor.yaml Il servizio attesta sé stesso mensilmente. Verificate che il bundle citato esista in `tenants/attestazione/snapshots/anchors/` nel repository e che l'hash dichiarato nel record corrisponda a quello nel file.
3. `CTL-cicd-pipeline` — https://github.com/SPAZIO-GENESI/gtf/blob/main/tenants/attestazione/registry/controls/CTL-cicd-pipeline.yaml Verificabile su GitHub Actions del repo `imgauth` (https://github.com/SPAZIO-GENESI/imgauth/actions): i run devono esistere ed essere effettivamente verdi/completati, non solo dichiarati.
4. `CTL-eidas-honest-positioning` — https://github.com/SPAZIO-GENESI/gtf/blob/main/tenants/attestazione/registry/controls/CTL-eidas-honest-positioning.yaml Questo è un controllo "di onestà" (non tecnico): verifica che il sito non sovra-dichiari conformità eIDAS che non ha. Leggete l'evidenza collegata e confrontatela con quanto scritto sul sito pubblico spaziogenesi.org.
5. **Una vostra scelta libera** — sfogliate `tenants/attestazione/registry/controls/` e scegliete un quinto `CTL-*` con `status: active` che vi incuriosisce o vi sembra critico.

Cosa fare per ciascuno dei 5

1. Aprite il file `CTL-*.yaml` → annotate `status` e leggete la descrizione.
2. Seguite `implemented_by` → aprite il file `IMP-*.yaml` collegato → lì trovate un riferimento a un file/percorso nel codice pubblico (es. un file in `imgauth/worker.js`). Andate a controllare che quel riferimento esista davvero (su GitHub potete usare la lente di ricerca del repository, tasto `/` sulla tastiera, per cercare una parola chiave).
3. Seguite `evidenced_by` → aprite il file `EVD-*.yaml` collegato → verificate che la prova descritta sia effettivamente osservabile dove dice (un URL da aprire, un file da leggere, un run CI da controllare) e che non sia scaduta o palesemente vecchia rispetto a quanto dichiarato.
4. Annotate per ciascuno: **conferma** (tutto combacia) o **rilievo** (qualcosa non torna, manca, o è ambiguo) con una riga di motivazione.

---

5. Passo 4 — Cadenze e decisioni: coerenza generale

Due controlli più rapidi (~30 minuti):

- Aprite `tenants/attestazione/registry/processes/` (i file `PRC-*.yaml`): ciascuno ha `frequency_days` (ogni quanto dovrebbe ripetersi) e, se già eseguito, `last_run` (l'ultima volta). Verificate che nessuna cadenza risulti scaduta rispetto a oggi senza una spiegazione nel registro.
- Scegliete 2-3 `ADR-*` citate dai controlli che avete già esaminato al passo precedente e verificate che esistano davvero nella cartella `tenants/attestazione/registry/decisions/` e che il contenuto (`context`/`decision`) sia coerente con quanto il controllo dichiara di fare.

---

6. Passo 5 — Scrivere il verbale

Non serve un documento formale complesso: bastano 1-2 pagine, in un formato a vostra scelta (va benissimo anche un file Word o PDF, non deve essere per forza Markdown). Struttura suggerita:

```
VERBALE DI REVIEW ESTERNA — GENESIS TRUST FRAMEWORK
Data: [gg/mm/aaaa]
Revisore: Radixia srl
Perimetro esaminato: registro pubblico gtf (commit [hash], data [gg/mm/aaaa])

1. Riproducibilità del punteggio (Passo 2)
   Esito: [superato / non superato]
   Note: [...]

2. Controlli esaminati (Passo 3)
   - CTL-hmac-canary: [conferma / rilievo] — [note]
   - CTL-dogfooding-anchor: [conferma / rilievo] — [note]
   - CTL-cicd-pipeline: [conferma / rilievo] — [note]
   - CTL-eidas-honest-positioning: [conferma / rilievo] — [note]
   - [quinto controllo scelto]: [conferma / rilievo] — [note]

3. Cadenze e coerenza (Passo 4)
   Esito: [...]

4. Rilievi complessivi
   [elenco, con gravità: bassa / media / alta]

5. Raccomandazioni
   [se presenti]

Conclusione generale: [una frase di sintesi]
```

Il **commit hash** da annotare nel verbale (per fissare esattamente quale versione del registro avete esaminato) si ottiene, dentro la cartella `gtf`, con:

```
git log -1 --format=%H
```

Come consegnarlo

Il modo più semplice: inviatelo via email a **it@spaziogenesi.org**. Se preferite (facoltativo, non richiesto) potete anche proporlo come Pull Request sul repository `gtf` — ma l'email va benissimo, se ne occupa poi Spazio Genesi ETS di registrarlo nel repository pubblico.

---

7. Cosa succede dopo (non è compito vostro, solo per contesto)

Una volta ricevuto il verbale, Spazio Genesi ETS lo pubblica nel repository come nuova evidenza (`EVD-review-esterna-2026`), trasforma eventuali rilievi in azioni correttive con scadenza, e aggiorna la data dell'ultima review sul processo. Da quel momento l'indicatore "Governance" dell'Open Trust Score riflette la prima evidenza di audit indipendente.

In caso di dubbi

Qualunque punto non sia chiaro, o comandi che diano errori inattesi, scrivete a **it@spaziogenesi.org** — meglio un chiarimento in più che un rilievo basato su un fraintendimento.